BÁO CÁO LUẬT BẢO MẬT (SECURITY RULES), BÀI THỰC HÀNH 6

Sinh viên: B23DCCC054 · Ứng dụng chat React Native + Firebase Realtime Database · Tệp luật: `database.rules.json`

1. Nguyên tắc thiết kế

- **Mặc định từ chối:** nhánh nào không khai báo `.read/.write` thì không ai đọc/ghi được; chỉ mở đúng quyền cần thiết cho từng nhánh.
- **Xác định thành viên** bằng dữ liệu đang có trên server: `root.child('conversations').child($convId).child('members').child(auth.uid).exists()`. Người ngoài không thể tự thêm mình vào nhóm nên không vượt qua được điều kiện này.
- **Quyền ghi lan xuống node con** (cascade), nên quyền ghi ở `$msgId` chỉ cấp khi tạo tin mới (`!data.exists()`). Thu hồi và cảm xúc được cấp riêng ở node con `recalled`, `reactions/$uid`.
- `.validate` kiểm tra dữ liệu: loại tin, độ dài văn bản, URL ảnh phải là `https://res.cloudinary.com/`, tọa độ hợp lệ, cảm xúc chỉ thuộc 5 emoji cho phép.

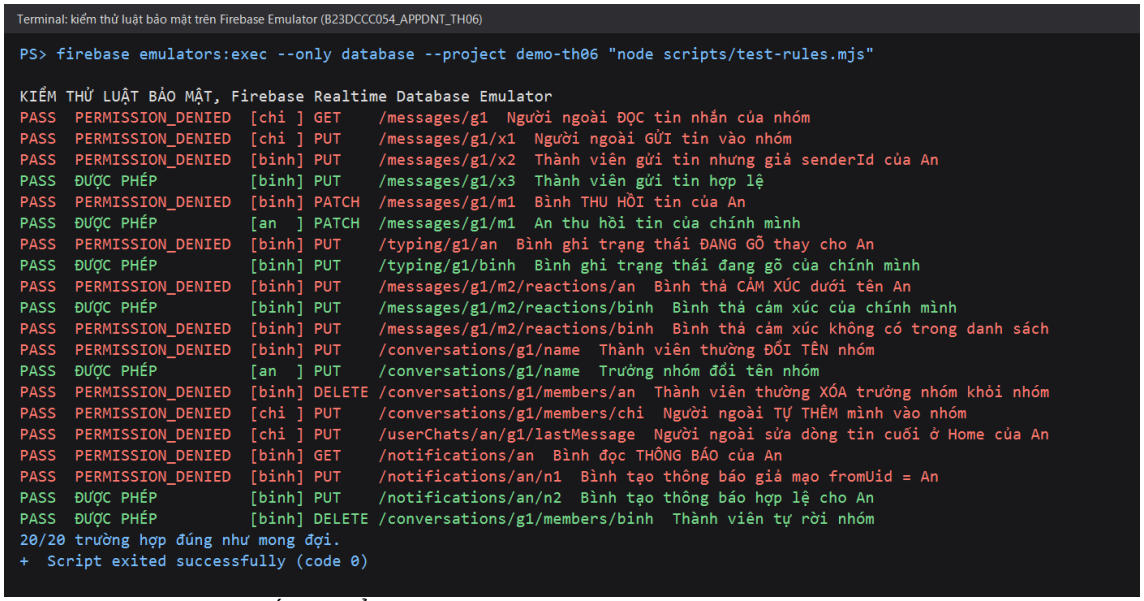
2. Các luật chính

Yêu cầu	Luật (rút gọn)	Ý nghĩa
Chỉ thành viên đọc/ghi tin nhắn	`messages/$convId .read: là thành viên` `$msgId .write: thành viên && !data.exists() && newData.senderId == auth.uid`	Người ngoài không đọc được; không ai giả mạo người gửi hay sửa tin cũ.
Chỉ người gửi được thu hồi	`recalled .write: data.parent().senderId == auth.uid && newData == true` `text/imageUrl: chỉ được xóa khi recalled == true`	Thu hồi = đánh dấu recalled và xóa nội dung, không xóa node.
Đang gõ chỉ của chính mình	`typing/$convId/$uid .write: $uid == auth.uid && là thành viên`	Không bật/tắt trạng thái gõ thay người khác.
Cảm xúc chỉ của chính mình	`reactions/$uid .write: $uid == auth.uid && là thành viên` `.validate: một trong` 👍 ❤️ 😂 😮 😢	Mỗi người một khóa riêng, đếm được số lượng.
Quản trị nhóm	`name, members/$uid, createdBy: chỉ createdBy (trưởng nhóm)` `members/$uid: cho phép auth.uid == $uid tự xóa (rời nhóm)`	Thành viên thường không đổi tên, không thêm/xóa người khác.
Home và số chưa đọc	`userChats/$uid/$convId .write: chủ sở hữu, hoặc thành viên cùng cuộc trò chuyện`	Cho phép multi-path update kèm increment(1).
Thông báo	`notifications/$uid .read: chủ sở hữu` `$id .write: chủ sở hữu, hoặc tạo mới với fromUid == auth.uid`	Không đọc trộm, không giả mạo người gửi.

Bảng 1. Tóm tắt luật bảo mật cho dữ liệu mới của bài 6

3. Chứng minh bằng thao tác bị từ chối

Script `scripts/test-rules.mjs` chạy trên Firebase Realtime Database Emulator với **đúng tệp database.rules.json** đã deploy, đóng vai An (trưởng nhóm), Bình (thành viên) và Chi (người ngoài). Kết quả: **20/20 trường hợp đúng như mong đợi**: 13 thao tác trái phép bị server trả về **PERMISSION_DENIED** (người ngoài đọc/gửi tin, giả senderId, thu hồi tin người khác, ghi typing/cảm xúc thay người khác, thành viên thường đổi tên nhóm, đọc hoặc giả mạo thông báo…), 7 thao tác hợp lệ được phép.



Hình 1. Kết quả kiểm thử luật: đỏ = PERMISSION_DENIED, xanh = được phép